

Nama : Dandi Taufik Hidayat

NIM : 2250081079

Mata Kuliah : Strategi Keamanan Perangkat Lunak

1. Form login menampilkan pesan: “*akun tidak ada*” saat username salah, dan “*password salah*” saat password salah.

a) Prinsip secure design yang relevan

- Least Common Mechanism
- Fail-Safe Defaults
- Information Disclosure

b) Alasannya

Ketika sistem menampilkan pesan yang berbeda saat username salah dan password salah adalah bentuk informasi disclosure atau memberikan informasi secara langsung, karena penyerang jadi tahu bahwa usernamenya ada yang salah tinggal passwordnya yang penyerang cari intinya si penyerang ini jadi tahu bahwa suatu akun memang ada di sistem. Hal tersebut bisa di manfaatkan untuk melakukan user enumeration attack.

Prinsip Fail-Safe Defaults menuntut agar sistem tetap aman bahkan ketika terjadi kesalahan, misalnya dengan memberikan pesan yang umum seperti “Kredensial tidak valid”. Sementara itu, Least Common Mechanism menekankan agar sistem tidak membagikan informasi atau mekanisme internal yang bisa dimanfaatkan oleh pihak lain.

Solusinya adalah menampilkan pesan kesalahan yang seragam, mencatat detail kesalahan di log server, dan menambahkan perlindungan seperti rate limiting serta account lockout setelah beberapa kali gagal login.

2. Endpoint `/reports/download?id=42` hanya memeriksa apakah pengguna sudah login, tidak memeriksa kepemilikan laporan.

a) Prinsip secure design yang relevan

- Complete Mediation
- Least Privilege

b) Alasannya

Endpoint ini hanya memeriksa status login, tetapi tidak memverifikasi apakah pengguna memiliki hak untuk mengakses laporan tersebut. Akibatnya, pengguna bisa mengakses atau mengunduh laporan milik orang lain dengan mengganti parameter id.

Hal ini melanggar prinsip Complete Mediation, karena setiap permintaan ke resource harus melalui proses otorisasi lengkap, serta Least Privilege, karena sistem memberikan akses lebih luas dari yang seharusnya.

Solusinya adalah dengan menambahkan pemeriksaan kepemilikan (ownership check) atau menerapkan kontrol akses berbasis peran (role-based access control), dan menggunakan identifier acak seperti UUID agar sulit ditebak.

3. Service “export pdf” berjalan sebagai admin database karena “biar gampang akses semua tabel”.

a) Prinsip secure design yang relevan

- Least Privilege
- Separation of Duties

b) Alasannya

Menjalankan layanan dengan hak akses admin menyebabkan risiko besar: jika layanan diserang, maka seluruh database dapat dikompromikan.

Prinsip Least Privilege menyatakan bahwa setiap proses atau komponen harus dijalankan dengan hak minimum yang dibutuhkan. Sedangkan Separation of Duties mendorong pemisahan hak istimewa agar satu kesalahan atau kebocoran tidak berdampak ke seluruh sistem.

Solusinya, jalankan service “export PDF” menggunakan akun database khusus dengan hak baca (read-only) terhadap tabel yang diperlukan saja, dan bukan akun admin. Pastikan juga ada audit log dan pembatasan koneksi.

4. Validasi input dilakukan di frontend saja; backend langsung memproses parameter query.

a) Prinsip secure design yang relevan

- Defense in Depth
- Complete Mediation

b) Alasannya

Validasi di sisi frontend saja tidak cukup karena mudah dilewati oleh pengguna atau penyerang (misalnya dengan memodifikasi request menggunakan tools seperti Postman atau Burp Suite). Jika backend tidak memverifikasi ulang data, sistem akan rentan terhadap serangan seperti SQL Injection, XSS, atau path traversal.

Prinsip Defense in Depth menyarankan penggunaan lapisan pertahanan ganda (frontend dan backend), sementara Complete Mediation memastikan setiap input yang diterima server diperiksa sebelum diproses.

Solusinya, lakukan validasi di sisi server, gunakan whitelist untuk tipe data yang diizinkan, serta batasi panjang dan format input.

5. Sistem punya 12 middleware keamanan, tapi sebagian tidak terdokumentasi dan sulit di-audit.

a) Prinsip secure design yang relevan

- Economy of Mechanism
- Open Design

b) Alasannya

Sistem keamanan yang terlalu kompleks dan tidak terdokumentasi menyulitkan proses audit, pemeliharaan, serta pengujian. Ini melanggar prinsip Economy of Mechanism, yang menekankan bahwa desain keamanan harus sederhana, konsisten, dan mudah dipahami.

Selain itu, Open Design menegaskan bahwa keamanan tidak boleh bergantung pada kerahasiaan mekanisme, melainkan pada kekuatan desain dan implementasinya yang bisa diverifikasi.

Solusinya adalah mendokumentasikan seluruh middleware, menyederhanakan konfigurasi, menghapus mekanisme yang tumpang tindih, dan melakukan audit keamanan secara rutin.